

# Apache Zeppelin 命令执行漏洞（CVE-2024-31861）预警

## 漏洞描述

Apache Zeppelin 中代码生成控制不当（“代码注入”）漏洞。攻击者可以使用 Shell解释器作为代码生成网关，系统org.apache.zeppelin.shell.ShellInterpreter类直接调用/sh来执行命令，没有进行过滤，导致RCE漏洞。

## 影响范围

0.10.1 <= Apache Zeppelin < 0.11.1

## 漏洞状态

| 漏洞细节 | 漏洞POC | 漏洞EXP | 在野利用 |
|------|-------|-------|------|
| 是    | 已公开   | 已公开   | 已知   |

## 风险等级

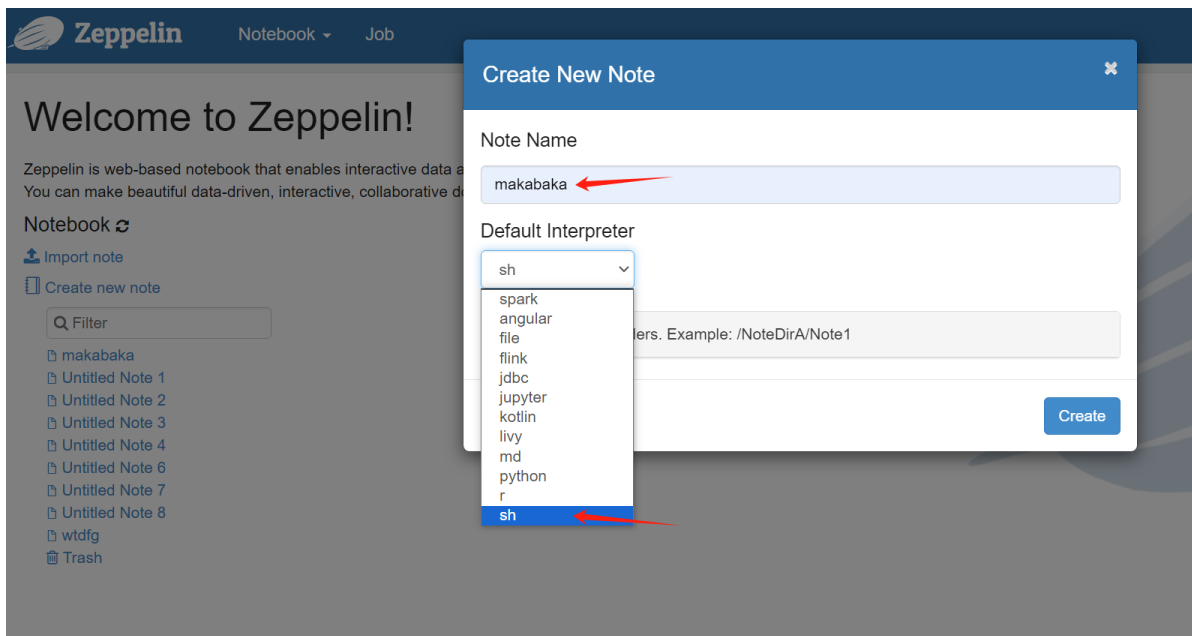
| 维度    | 评价 |
|-------|----|
| 威胁等级  | 高危 |
| 影响面   | 广  |
| 攻击者价值 | 中  |
| 利用难度  | 低  |

## 漏洞复现

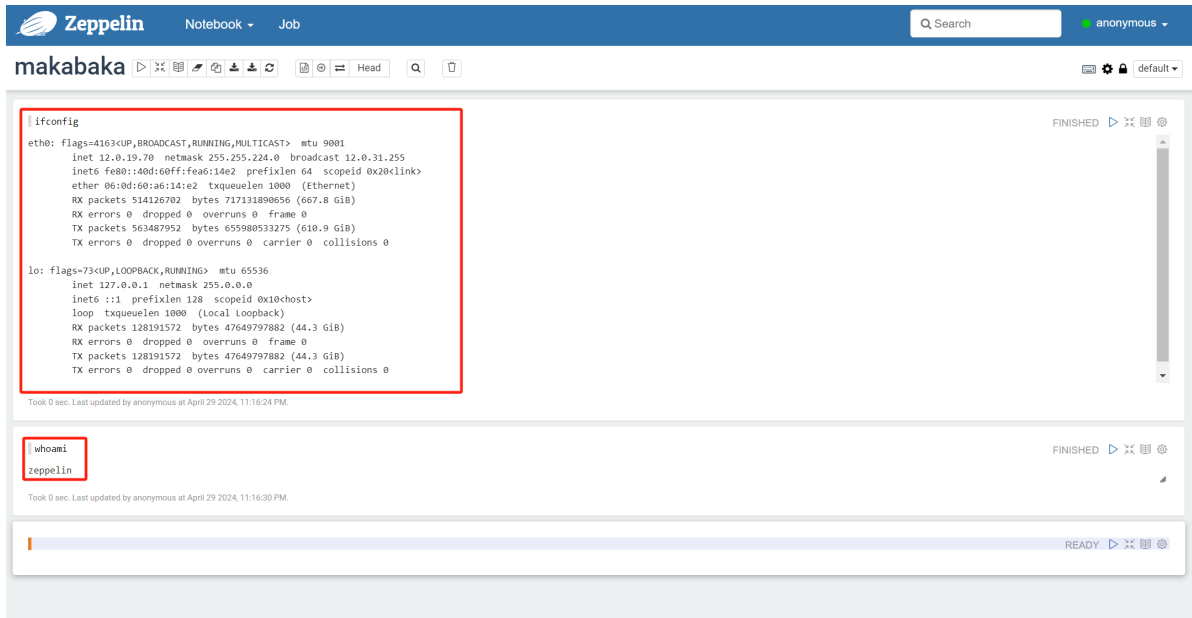
FOFA: app="APACHE-Zeppelin"

POC/EXP:

创建笔记，选择sh



直接执行命令



## 修复方案

官方修复:

升级至最新版本。

利用安全组设置其仅对可信地址开放。

进行安全更新方法:

<https://github.com/apache/zeppelin/tags>